PANDAX / INDEPENDENT ANSWER KEY

What should PandaX find?

Reference 2.0 | Public-source research: 7 September 2026

Pick the exact input below. Each page tells you which named CVEs should appear, which should not be active, and what still needs human review. Write the observed PandaX result in the last column.

Independence: expected vulnerabilities come from the linked public sources. PandaX findings and built-in pass/fail checks are not used to set the answers. Repository input declarations establish scope only. The later test comparison is a separate report.

Input / release	Should find	Should not flag	Page
OpenWrt 19.07.0	3	5	2
OpenWrt 19.07.1	2	6	3
OpenWrt 19.07.5	2	6	4
OpenWrt 19.07.6	0	8	5
curl / libcurl 8.3.0	3	1	6
curl / libcurl 8.4.0	1	3	7
OpenSSL 1.0.1f / s_server	3	0	8
OpenSSL 1.0.1g / s_server	2	1	9
SmartHub 2.3.1 / directory	10	0	10
SmartHub 2.3.1 / zip	10	0	11
Struts 2.5.12 / full libraries	3	0	12
Struts 2.5.12 / min libraries	2	1	13
Struts 2.5.33 / min libraries	0	3	14
Example web application 1.0.0 / SBOM	1	0	15

Counts refer only to the named checks in this reference. They are not total CVE counts. Extra findings need separate advisory review; a release with no positive checks here may still contain other vulnerabilities.

How to compare

1. Select the exact release. **2.** Check the component/version in **Artifacts**. **3.** Search each CVE in **Vulnerabilities** with filters cleared. **4.** Inspect **Evidence / applicability** and the fixed/excluded reason. **5.** Record MATCH, MISSING, FALSE POSITIVE or UNRESOLVED.

Missing component or failed scan = unresolved coverage, never a clean pass. A component-version finding is not proof that your application can be exploited.

INPUT 01 / ARTIFACT

OpenWrt 19.07.0

Select: **release:openwrt-19.07.0**

3 named CVE(s) should be found | 5 should not be active

CVE / vulnerability	Component	Expected PoC result	Your observation
CVE-2020-7248 [W1] JSON serialization stack overflow	libubox	**SHOULD FIND**	
CVE-2020-25681 [W2] DNSSEC RRset overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25682 [W2] DNSSEC name extraction overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25683 [W2] DNSSEC rdata overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25684 [W2] DNS response validation	dnsmasq	**SHOULD FIND**	
CVE-2020-25685 [W2] DNS response hash validation	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25686 [W2] DNS duplicate-query validation	dnsmasq	**SHOULD FIND**	
CVE-2020-25687 [W2] DNSSEC RRset overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	

First check the inventory

libubox 2019-12-28-cd75136b-1; **libblobmsg-json** 2019-12-28-cd75136b-1; **dnsmasq** 2.80-15; **ubus** 2019-12-27-041c9d1c-1; **rpcd** 2019-11-10-77ad0de0-1; **uhttpd** 2019-12-22-5f9ae573-1. [M1]

What changes the interpretation

Confirm the standard dnsmasq package. A custom dnsmasq-full build needs different applicability checks. Runtime input paths and DNS service configuration remain unverified. [W1] [W2]

19.07.0 to 19.07.1 fixes the libubox check. 19.07.5 to 19.07.6 fixes two standard-dnsmasq checks; five variant exclusions remain exclusions.

Specific CVE fix boundaries: CVE-2020-7248 = 19.07.1; CVE-2020-25684 = 2.80-16.2; CVE-2020-25686 = 2.80-16.2. These are historical boundaries, not deployment recommendations.

INPUT 02 / ARTIFACT

OpenWrt 19.07.1

Select: **release:openwrt-19.07.1**

2 named CVE(s) should be found | 6 should not be active

CVE / vulnerability	Component	Expected PoC result	Your observation
CVE-2020-7248 [W1] JSON serialization stack overflow	libubox	**NO ACTIVE FINDING** Fixed	
CVE-2020-25681 [W2] DNSSEC RRset overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25682 [W2] DNSSEC name extraction overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25683 [W2] DNSSEC rdata overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25684 [W2] DNS response validation	dnsmasq	**SHOULD FIND**	
CVE-2020-25685 [W2] DNS response hash validation	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25686 [W2] DNS duplicate-query validation	dnsmasq	**SHOULD FIND**	
CVE-2020-25687 [W2] DNSSEC RRset overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	

First check the inventory

libubox 2020-01-20-43a103ff-1; **libblobmsg-json** 2020-01-20-43a103ff-1; **dnsmasq** 2.80-15; **ubus** 2019-12-27-041c9d1c-1; **rpcd** 2019-11-10-77ad0de0-1; **uhttpd** 2019-12-22-5f9ae573-1. [M2]

What changes the interpretation

Confirm the standard dnsmasq package. A custom dnsmasq-full build needs different applicability checks. Runtime input paths and DNS service configuration remain unverified. [W1] [W2]

> 19.07.0 to 19.07.1 fixes the libubox check. 19.07.5 to 19.07.6 fixes two standard-dnsmasq checks; five variant exclusions remain exclusions.

Specific CVE fix boundaries: CVE-2020-7248 = 19.07.1; CVE-2020-25684 = 2.80-16.2; CVE-2020-25686 = 2.80-16.2. These are historical boundaries, not deployment recommendations.

INPUT 03 / ARTIFACT

OpenWrt 19.07.5

Select: **release:openwrt-19.07.5**

2 named CVE(s) should be found | 6 should not be active

CVE / vulnerability	Component	Expected PoC result	Your observation
CVE-2020-7248 [W1] JSON serialization stack overflow	libubox	**NO ACTIVE FINDING** Fixed	
CVE-2020-25681 [W2] DNSSEC RRset overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25682 [W2] DNSSEC name extraction overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25683 [W2] DNSSEC rdata overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25684 [W2] DNS response validation	dnsmasq	**SHOULD FIND**	
CVE-2020-25685 [W2] DNS response hash validation	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25686 [W2] DNS duplicate-query validation	dnsmasq	**SHOULD FIND**	
CVE-2020-25687 [W2] DNSSEC RRset overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	

First check the inventory

libubox 2020-05-25-66195aee-1; **libblobmsg-json** 2020-05-25-66195aee-1; **dnsmasq** 2.80-16.1; **ubus** 2019-12-27-041c9d1c-1; **rpcd** 2020-05-26-67c8a3fd-1; **uhttpd** 2020-10-01-3abcc891-1. [M3]

What changes the interpretation

Confirm the standard dnsmasq package. A custom dnsmasq-full build needs different applicability checks. Runtime input paths and DNS service configuration remain unverified. [W1] [W2]

> 19.07.0 to 19.07.1 fixes the libubox check. 19.07.5 to 19.07.6 fixes two standard-dnsmasq checks; five variant exclusions remain exclusions.

Specific CVE fix boundaries: CVE-2020-7248 = 19.07.1; CVE-2020-25684 = 2.80-16.2; CVE-2020-25686 = 2.80-16.2. These are historical boundaries, not deployment recommendations.

INPUT 04 / ARTIFACT

OpenWrt 19.07.6

Select: **release:openwrt-19.07.6**

0 named CVE(s) should be found | 8 should not be active

CVE / vulnerability	Component	Expected PoC result	Your observation
CVE-2020-7248 [W1] JSON serialization stack overflow	libubox	**NO ACTIVE FINDING** Fixed	
CVE-2020-25681 [W2] DNSSEC RRset overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25682 [W2] DNSSEC name extraction overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25683 [W2] DNSSEC rdata overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25684 [W2] DNS response validation	dnsmasq	**NO ACTIVE FINDING** Fixed	
CVE-2020-25685 [W2] DNS response hash validation	dnsmasq	**NO ACTIVE FINDING** Excluded variant	
CVE-2020-25686 [W2] DNS duplicate-query validation	dnsmasq	**NO ACTIVE FINDING** Fixed	
CVE-2020-25687 [W2] DNSSEC RRset overflow	dnsmasq	**NO ACTIVE FINDING** Excluded variant	

First check the inventory

libubox 2020-05-25-66195aee-1; **libblobmsg-json** 2020-05-25-66195aee-1; **dnsmasq** 2.80-16.2; **ubus** 2019-12-27-041c9d1c-1; **rpcd** 2020-05-26-67c8a3fd-1; **uhttpd** 2020-10-01-3abcc891-1. [M4]

What changes the interpretation

Confirm the standard dnsmasq package. A custom dnsmasq-full build needs different applicability checks. Runtime input paths and DNS service configuration remain unverified. [W1] [W2]

19.07.0 to 19.07.1 fixes the libubox check. 19.07.5 to 19.07.6 fixes two standard-dnsmasq checks; five variant exclusions remain exclusions.

Specific CVE fix boundaries: CVE-2020-7248 = 19.07.1; CVE-2020-25684 = 2.80-16.2; CVE-2020-25686 = 2.80-16.2. These are historical boundaries, not deployment recommendations.

INPUT 05 / ARTIFACT

curl / libcurl 8.3.0

Select: **release:curl-8.3.0**

3 named CVE(s) should be found | 1 should not be active

CVE / vulnerability	Component	Expected PoC result	Your observation
CVE-2023-38545 [C1] SOCKS5 heap buffer overflow	libcurl	**SHOULD FIND**	
CVE-2023-38546 [C2] Cookie injection via duplicated handle	libcurl	**SHOULD FIND**	
CVE-2023-46218 [C3] Mixed-case cookie PSL bypass	libcurl	**SHOULD FIND**	
CVE-2023-38039 [C4] Unbounded response-header memory	libcurl	**NO ACTIVE FINDING** Fixed	

First check the inventory

libcurl 8.3.0; **curl** 8.3.0. [C5]

What changes the interpretation

Source inventory does not establish a running application. For CVE-2023-38545, the CLI default 100 KiB buffer prevents the heap overflow, but a low --limit-rate can reduce it below 65,541 bytes. The advisory also documents another hostname-length consequence even with a larger buffer. Do not label the whole CVE harmless from buffer size alone. [C1] [C2] [C3] [C4]

> 8.3.0 to 8.4.0 fixes CVE-2023-38545 and CVE-2023-38546. CVE-2023-46218 must remain a finding.

Specific CVE fix boundaries: CVE-2023-38545 = 8.4.0; CVE-2023-38546 = 8.4.0; CVE-2023-46218 = 8.5.0; CVE-2023-38039 = 8.3.0. These are historical boundaries, not deployment recommendations.

INPUT 06 / ARTIFACT

curl / libcurl 8.4.0

Select: **release:curl-8.4.0**

1 named CVE(s) should be found | 3 should not be active

CVE / vulnerability	Component	Expected PoC result	Your observation
CVE-2023-38545 [C1] SOCKS5 heap buffer overflow	libcurl	**NO ACTIVE FINDING** Fixed	
CVE-2023-38546 [C2] Cookie injection via duplicated handle	libcurl	**NO ACTIVE FINDING** Fixed	
CVE-2023-46218 [C3] Mixed-case cookie PSL bypass	libcurl	**SHOULD FIND**	
CVE-2023-38039 [C4] Unbounded response-header memory	libcurl	**NO ACTIVE FINDING** Fixed	

First check the inventory

libcurl 8.4.0; **curl** 8.4.0. [C5]

What changes the interpretation

Source inventory does not establish a running application. For CVE-2023-38545, the CLI default 100 KiB buffer prevents the heap overflow, but a low --limit-rate can reduce it below 65,541 bytes. The advisory also documents another hostname-length consequence even with a larger buffer. Do not label the whole CVE harmless from buffer size alone. [C1] [C2] [C3] [C4]

> 8.3.0 to 8.4.0 fixes CVE-2023-38545 and CVE-2023-38546. CVE-2023-46218 must remain a finding.

Specific CVE fix boundaries: CVE-2023-38545 = 8.4.0; CVE-2023-38546 = 8.4.0; CVE-2023-46218 = 8.5.0; CVE-2023-38039 = 8.3.0. These are historical boundaries, not deployment recommendations.

INPUT 07 / ARTIFACT

OpenSSL 1.0.1f / s_server

Select: **release:openssl-1.0.1f**

3 named CVE(s) should be found | 0 should not be active

CVE / vulnerability	Component	Expected PoC result	Your observation
CVE-2014-0160 [O1] Heartbleed memory disclosure	libssl	**SHOULD FIND**	
CVE-2014-0224 [O2] CCS man-in-the-middle weakness	libssl	**SHOULD FIND**	
CVE-2014-0195 [O2] DTLS fragment buffer overflow	libssl	**SHOULD FIND**	

First check the inventory

libssl 1.0.1f. [O1] [O2]

What changes the interpretation

Confirm the actual TLS library and build flags, including OPENSSL_NO_HEARTBEATS. Source-only scans cannot establish deployed reachability. Keep DTLS-specific conditions separate from TLS server operation. [O1] [O2]

1.0.1f to 1.0.1g fixes Heartbleed. The two June 2014 CVEs remain affected at the component-version level.

Specific CVE fix boundaries: CVE-2014-0160 = 1.0.1g; CVE-2014-0224 = 1.0.1h; CVE-2014-0195 = 1.0.1h. These are historical boundaries, not deployment recommendations.

INPUT 08 / ARTIFACT

OpenSSL 1.0.1g / s_server

Select: **release:openssl-1.0.1g**

2 named CVE(s) should be found | 1 should not be active

CVE / vulnerability	Component	Expected PoC result	Your observation
CVE-2014-0160 [O1] Heartbleed memory disclosure	libssl	**NO ACTIVE FINDING** Fixed	
CVE-2014-0224 [O2] CCS man-in-the-middle weakness	libssl	**SHOULD FIND**	
CVE-2014-0195 [O2] DTLS fragment buffer overflow	libssl	**SHOULD FIND**	

First check the inventory

libssl 1.0.1g. [O1] [O2]

What changes the interpretation

Confirm the actual TLS library and build flags, including OPENSSL_NO_HEARTBEATS. Source-only scans cannot establish deployed reachability. Keep DTLS-specific conditions separate from TLS server operation. [O1] [O2]

1.0.1f to 1.0.1g fixes Heartbleed. The two June 2014 CVEs remain affected at the component-version level.

Specific CVE fix boundaries: CVE-2014-0160 = 1.0.1g; CVE-2014-0224 = 1.0.1h; CVE-2014-0195 = 1.0.1h. These are historical boundaries, not deployment recommendations.

INPUT 09 / ARTIFACT

SmartHub 2.3.1 / directory

Input: fixtures/smarthub-sh100

10 named CVE(s) should be found | 0 should not be active

CVE / vulnerability	Component	Expected PoC result	Your observation
CVE-2020-11023 [J1] HTML injection / XSS	jquery	**SHOULD FIND**	
CVE-2020-8203 [J2] Prototype pollution	lodash	**SHOULD FIND**	
CVE-2021-44906 [J3] Prototype pollution	minimist	**SHOULD FIND**	
CVE-2022-24771 [J4] RSA signature verification weakness	node-forge	**SHOULD FIND**	
CVE-2021-25293 [P1] SGI image out-of-bounds read	pillow	**SHOULD FIND**	
CVE-2018-18074 [P2] Authorization header disclosure	requests	**SHOULD FIND**	
CVE-2019-11324 [P3] Custom certificate trust bypass	urllib3	**SHOULD FIND**	
CVE-2020-14343 [P4] Unsafe YAML construction	PyYAML	**SHOULD FIND**	
CVE-2019-10906 [P5] Template sandbox escape	Jinja2	**SHOULD FIND**	
CVE-2021-44228 [L1] Log4Shell	log4j-core	**SHOULD FIND**	

First check the inventory

jquery 3.4.0; **lodash** 4.17.15; **minimist** 1.2.0; **node-forge** 0.9.0; **pillow** 8.1.0; **requests** 2.19.1; **urllib3** 1.24.1; **PyYAML** 5.1; **Jinja2** 2.10; **log4j-core** 2.14.1.

What changes the interpretation

Synthetic product: these are public-advisory checks for its declared dependencies, not an online attestation of the product. Log4j requires log4j-core, not only log4j-api. For CVE-2023-4863, a Pillow requirement alone does not prove the installed libwebp version; inspect the actual wheel/native library. Missing build/configuration evidence is unresolved. [J1] [J2] [J3] [J4] [P1] [P2] [P3] [P4] [P5] [L1]

Native WebP build evidence: [P6]

> The directory and ZIP should agree only when their contents agree. Compare each input independently; do not infer that a missing JAR was patched.

Specific CVE fix boundaries: CVE-2020-11023 = 3.5.0; CVE-2020-8203 = 4.17.19; CVE-2021-44906 = 1.2.6 (1.x); CVE-2022-24771 = 1.3.0; CVE-2021-25293 = 8.1.1; CVE-2018-18074 = 2.20.0; CVE-2019-11324 = 1.24.2; CVE-2020-14343 = 5.4; CVE-2019-10906 = 2.10.1; CVE-2021-44228 = 2.15.0 initial fix. These are historical boundaries, not deployment recommendations.

INPUT 10 / ARTIFACT

SmartHub 2.3.1 / zip

Input: fixtures/smarthub-sh100-v2.3.1.zip

10 named CVE(s) should be found | 0 should not be active

CVE / vulnerability	Component	Expected PoC result	Your observation
CVE-2020-11023 [J1] HTML injection / XSS	jquery	**SHOULD FIND**	
CVE-2020-8203 [J2] Prototype pollution	lodash	**SHOULD FIND**	
CVE-2021-44906 [J3] Prototype pollution	minimist	**SHOULD FIND**	
CVE-2022-24771 [J4] RSA signature verification weakness	node-forge	**SHOULD FIND**	
CVE-2021-25293 [P1] SGI image out-of-bounds read	pillow	**SHOULD FIND**	
CVE-2018-18074 [P2] Authorization header disclosure	requests	**SHOULD FIND**	
CVE-2019-11324 [P3] Custom certificate trust bypass	urllib3	**SHOULD FIND**	
CVE-2020-14343 [P4] Unsafe YAML construction	PyYAML	**SHOULD FIND**	
CVE-2019-10906 [P5] Template sandbox escape	Jinja2	**SHOULD FIND**	
CVE-2021-44228 [L1] Log4Shell	log4j-core	**SHOULD FIND**	

First check the inventory

jquery 3.4.0; **lodash** 4.17.15; **minimist** 1.2.0; **node-forge** 0.9.0; **pillow** 8.1.0; **requests** 2.19.1; **urllib3** 1.24.1; **PyYAML** 5.1; **Jinja2** 2.10; **log4j-core** 2.14.1.

What changes the interpretation

Synthetic product: these are public-advisory checks for its declared dependencies, not an online attestation of the product. Log4j requires log4j-core, not only log4j-api. For CVE-2023-4863, a Pillow requirement alone does not prove the installed libwebp version; inspect the actual wheel/native library. Missing build/configuration evidence is unresolved. [J1] [J2] [J3] [J4] [P1] [P2] [P3] [P4] [P5] [L1]

Native WebP build evidence: [P6]

> The directory and ZIP should agree only when their contents agree. Compare each input independently; do not infer that a missing JAR was patched.

Specific CVE fix boundaries: CVE-2020-11023 = 3.5.0; CVE-2020-8203 = 4.17.19; CVE-2021-44906 = 1.2.6 (1.x); CVE-2022-24771 = 1.3.0; CVE-2021-25293 = 8.1.1; CVE-2018-18074 = 2.20.0; CVE-2019-11324 = 1.24.2; CVE-2020-14343 = 5.4; CVE-2019-10906 = 2.10.1; CVE-2021-44228 = 2.15.0 initial fix. These are historical boundaries, not deployment recommendations.

INPUT 11 / ARTIFACT

Struts 2.5.12 / full libraries

Official archive: struts-2.5.12-lib.zip

3 named CVE(s) should be found | 0 should not be active

CVE / vulnerability	Component	Expected PoC result	Your observation
CVE-2018-11776 [S2] Namespace handling / RCE	struts2-core	**SHOULD FIND**	
CVE-2023-50164 [S3] File upload path traversal	struts2-core	**SHOULD FIND**	
CVE-2017-9805 [S1] REST XML deserialization / RCE	struts2-rest-plugin	**SHOULD FIND**	

First check the inventory

struts2-core 2.5.12; **struts2-rest-plugin** 2.5.12. [A1]

What changes the interpretation

The full 2.5.12 ZIP contains 93 JARs, including REST plugin 2.5.12 and XStream 1.4.8. Each minimum ZIP contains 8 JARs without REST plugin. These counts were independently obtained from official ZIP entries. Plugin presence does not prove XML endpoints or vulnerable application configuration. [S2] [S3] [S1]

> 2.5.12 minimum: two named core findings, no REST-plugin finding. 2.5.33 minimum: none of these three named CVEs should be active; other CVEs are outside this selected baseline.

Specific CVE fix boundaries: CVE-2018-11776 = 2.5.17; CVE-2023-50164 = 2.5.33; CVE-2017-9805 = 2.5.13. These are historical boundaries, not deployment recommendations.

INPUT 12 / ARTIFACT

Struts 2.5.12 / min libraries

Official archive: struts-2.5.12-min-lib.zip

2 named CVE(s) should be found | 1 should not be active

CVE / vulnerability	Component	Expected PoC result	Your observation
CVE-2018-11776 [S2] Namespace handling / RCE	struts2-core	**SHOULD FIND**	
CVE-2023-50164 [S3] File upload path traversal	struts2-core	**SHOULD FIND**	
CVE-2017-9805 [S1] REST XML deserialization / RCE	struts2-rest-plugin	**NO ACTIVE FINDING** Excluded variant	

First check the inventory

struts2-core 2.5.12. [A2]

What changes the interpretation

The full 2.5.12 ZIP contains 93 JARs, including REST plugin 2.5.12 and XStream 1.4.8. Each minimum ZIP contains 8 JARs without REST plugin. These counts were independently obtained from official ZIP entries. Plugin presence does not prove XML endpoints or vulnerable application configuration. [S2] [S3] [S1]

> 2.5.12 minimum: two named core findings, no REST-plugin finding. 2.5.33 minimum: none of these three named CVEs should be active; other CVEs are outside this selected baseline.

Specific CVE fix boundaries: CVE-2018-11776 = 2.5.17; CVE-2023-50164 = 2.5.33; CVE-2017-9805 = 2.5.13. These are historical boundaries, not deployment recommendations.

INPUT 13 / ARTIFACT

Struts 2.5.33 / min libraries

Official archive: struts-2.5.33-min-lib.zip

0 named CVE(s) should be found | 3 should not be active

CVE / vulnerability	Component	Expected PoC result	Your observation
CVE-2018-11776 [S2] Namespace handling / RCE	struts2-core	**NO ACTIVE FINDING** Fixed	
CVE-2023-50164 [S3] File upload path traversal	struts2-core	**NO ACTIVE FINDING** Fixed	
CVE-2017-9805 [S1] REST XML deserialization / RCE	struts2-rest-plugin	**NO ACTIVE FINDING** Excluded variant	

First check the inventory

struts2-core 2.5.33. [A3]

What changes the interpretation

The full 2.5.12 ZIP contains 93 JARs, including REST plugin 2.5.12 and XStream 1.4.8. Each minimum ZIP contains 8 JARs without REST plugin. These counts were independently obtained from official ZIP entries. Plugin presence does not prove XML endpoints or vulnerable application configuration. [S2] [S3] [S1]

> 2.5.12 minimum: two named core findings, no REST-plugin finding. 2.5.33 minimum: none of these three named CVEs should be active; other CVEs are outside this selected baseline.

Specific CVE fix boundaries: CVE-2018-11776 = 2.5.17; CVE-2023-50164 = 2.5.33; CVE-2017-9805 = 2.5.13. These are historical boundaries, not deployment recommendations.

INPUT 14 / SBOM

Example web application 1.0.0 / SBOM

Input: fixtures/example-sbom.cdx.json

1 named CVE(s) should be found | 0 should not be active

CVE / vulnerability	Component	Expected PoC result	Your observation
CVE-2020-11023 [J1] HTML injection / XSS	jquery	SHOULD FIND	

First check the inventory

jquery 3.4.0; **internal-device-agent** 1.0.0.

What changes the interpretation

The internal-device-agent has no public identity or versioned Package URL in the supplied SBOM. Preserve it in the inventory and label vulnerability coverage unresolved / not scanned. Do not infer that it has zero vulnerabilities. No runtime use of jQuery is established by the SBOM. [J1]

> New input in the pulled update. Verify both components are retained, jQuery is matched, and the unidentified component is visibly not scanned.

Specific CVE fix boundaries: CVE-2020-11023 = 3.5.0. These are historical boundaries, not deployment recommendations.

PUBLIC SOURCES

Source register 1 of 2

The expected answers above are deductions from these public advisories and official release artifacts.

[W1] OpenWrt: libubox advisory, 31 Jan 2020
https://openwrt.org/advisory/2020-01-31-2

[W2] OpenWrt: DNSpooq advisory, 19 Jan 2021
https://openwrt.org/advisory/2021-01-19-1

[M1] OpenWrt 19.07.0: official x86/64 generic manifest
https://downloads.openwrt.org/releases/19.07.0/targets/x86/64/openwrt-19.07.0-x86-64-generic.manifest

[M2] OpenWrt 19.07.1: official x86/64 generic manifest
https://downloads.openwrt.org/releases/19.07.1/targets/x86/64/openwrt-19.07.1-x86-64-generic.manifest

[M3] OpenWrt 19.07.5: official x86/64 generic manifest
https://downloads.openwrt.org/releases/19.07.5/targets/x86/64/openwrt-19.07.5-x86-64-generic.manifest

[M4] OpenWrt 19.07.6: official x86/64 generic manifest
https://downloads.openwrt.org/releases/19.07.6/targets/x86/64/openwrt-19.07.6-x86-64-generic.manifest

[C1] curl: SOCKS5 heap buffer overflow
https://curl.se/docs/CVE-2023-38545.html

[C2] curl: cookie injection with none file
https://curl.se/docs/CVE-2023-38546.html

[C3] curl: cookie mixed case PSL bypass
https://curl.se/docs/CVE-2023-46218.html

[C4] curl: HTTP headers eat all memory
https://curl.se/docs/CVE-2023-38039.html

[C5] curl: versions and source version identification
https://curl.se/docs/versions.html

[O1] OpenSSL: Heartbleed advisory, 7 Apr 2014
https://openssl-library.org/news/secadv/20140407.txt

[O2] OpenSSL: security advisory, 5 Jun 2014
https://openssl-library.org/news/secadv/20140605.txt

[J1] jQuery maintainer: CVE-2020-11023
https://github.com/jquery/jquery/security/advisories/GHSA-jpcq-cgw6-v4j6

[J2] GitHub reviewed advisory: lodash CVE-2020-8203
https://github.com/advisories/GHSA-p6mc-m468-83gw

PUBLIC SOURCES

Source register 2 of 2

The expected answers above are deductions from these public advisories and official release artifacts.

[J3] GitHub reviewed advisory: minimist CVE-2021-44906

https://github.com/advisories/GHSA-xvch-5gv4-984h

[J4] Forge maintainer: CVE-2022-24771

https://github.com/digitalbazaar/forge/security/advisories/GHSA-cfm4-qjh2-4765

[P1] Pillow 8.1.1 security release notes

https://pillow.readthedocs.io/en/stable/releasenotes/8.1.1.html

[P2] Requests maintainer: 2.20.0 release history

https://github.com/psf/requests/blob/main/HISTORY.md

[P3] urllib3 team disclosure: CVE-2019-11324

https://seclists.org/oss-sec/2019/q2/50

[P4] GitHub reviewed advisory: PyYAML CVE-2020-14343

https://github.com/advisories/GHSA-8q59-q68h-6hv4

[P5] Jinja maintainer: 2.10.1 security release

https://palletsprojects.com/blog/jinja-2-10-1-released

[P6] Pillow 10.0.1: updated libwebp wheels

https://pillow.readthedocs.io/en/stable/releasenotes/10.0.1.html

[L1] Apache Logging: Log4j security advisories

https://logging.apache.org/security.html

[S1] Apache Struts: S2-052 / CVE-2017-9805

https://cwiki.apache.org/confluence/display/WW/S2-052

[S2] Apache Struts: S2-057 / CVE-2018-11776

https://cwiki.apache.org/confluence/display/WW/S2-057

[S3] Apache Struts: S2-066 / CVE-2023-50164

https://cwiki.apache.org/confluence/display/WW/S2-066

[A1] Apache archive: Struts 2.5.12 full libraries

https://archive.apache.org/dist/struts/2.5.12/struts-2.5.12-lib.zip

[A2] Apache archive: Struts 2.5.12 minimum libraries

https://archive.apache.org/dist/struts/2.5.12/struts-2.5.12-min-lib.zip

[A3] Apache archive: Struts 2.5.33 minimum libraries

https://archive.apache.org/dist/struts/2.5.33/struts-2.5.33-min-lib.zip

Limits of this answer key

No exhaustive finding counts, live EPSS scores, KEV totals or regulatory deadlines are prescribed. Synthetic product declarations cannot establish deployed components, build flags or runtime reachability. Public advisories establish conditional component-level expectations.